

Unit 1: Ethical Hacking Overview

Part 2

By Dr. Indu Singh
CSE Dept, DTU

Dr. Indu Singh CSE DTU

What is Footprinting?

Footprinting is the process of collecting as much information as possible about a target organization before launching an attack.

Objectives:

- Identify IP addresses
- Discover domain information
- Find employee details
- Locate email addresses
- Learn network architecture
- Understand technologies being used

Types of Footprinting: Passive footprinting

Passive footprinting is the process of gathering information about a target **without directly interacting** with its systems, making the activity difficult to detect.

Common Sources

- Google Search (Google Dorking)
- LinkedIn employee profiles
- Company website
- Social media (Facebook, X, Instagram)
- Job portals (Indeed, Naukri, LinkedIn Jobs)
- WHOIS records
- DNS and public records
- News articles and press releases

Passive footprinting

Information Collected

- Organization details
- Employee names and email formats
- Domain names and IP addresses
- Technology stack and software used
- Office locations and contact information

Advantages

- Stealthy and difficult to detect
- No direct interaction with the target
- Low cost and easy to perform
- Helps plan further security assessments
- Provides valuable intelligence before active testing

Types of Footprinting: Active footprinting

Active footprinting is the process of gathering information by **directly interacting with the target's systems or network**, making the activity potentially detectable.

Common Techniques

- Ping
- Traceroute
- DNS queries
- Banner grabbing
- Port scanning
- Network scanning
- Service enumeration

Active footprinting

Information Collected

- Live hosts and active devices
- Open ports and running services
- Operating system details
- Network topology
- Service versions and configurations

Advantages

- Provides accurate and real-time information
- Identifies active hosts and services
- Reveals current network configuration
- Helps detect exposed vulnerabilities
- Useful for penetration testing and security assessments

Information Collected During Footprinting

Network Information

- IP ranges
- Domains
- Subdomains

Organization Information

- Employees
- Departments
- Office locations

Technical Information

- Web servers
- Email servers
- Firewalls



Example

Company: Google LLC

Website: google.com

Mail Server: smtp.google.com (public mail service)

Public DNS Servers:

- ns1.google.com
- ns2.google.com
- ns3.google.com
- ns4.google.com

Public IP (Example): 8.8.8.8 (Google Public DNS)

Footprinting Tools

Tool	Purpose
WHOIS	Retrieves domain registration details, including owner, registrar, and registration dates.
nslookup	Queries DNS servers to obtain domain names, IP addresses, and other DNS records.
dig	Performs detailed DNS lookups to retrieve records such as A, MX, NS, and TXT.
Maltego	Maps relationships between people, domains, organizations, and other digital assets.
Shodan	Searches for internet-connected devices and identifies exposed services and vulnerabilities.
Netcraft	Provides information about websites, hosting providers, technologies, and security details.
Google Dorks	Uses advanced Google search operators to discover publicly accessible sensitive information.

Social Engineering

Social engineering is a cyberattack technique in which attackers manipulate people into revealing confidential information or performing actions that compromise security.

Key Characteristics

- Exploits **human psychology** instead of software or hardware vulnerabilities.
- Uses trust, fear, curiosity, urgency, or authority to deceive victims.
- Targets employees, customers, and organizations of all sizes.
- Can be carried out through emails, phone calls, text messages, social media, or in-person interactions.
- Often serves as the first step in larger cyberattacks such as malware infections or data breaches.

Social Engineering

Objectives of Social Engineering

- Steal usernames and passwords.
- Obtain financial or personal information.
- Gain unauthorized access to systems.
- Trick users into installing malware.
- Bypass security policies and controls.

Why Social Engineering Works

Reasons

- Humans are often the weakest link in cybersecurity because they can make mistakes or be easily deceived.
- Attackers exploit emotions such as trust, fear, curiosity, urgency, or greed to manipulate victims.
- People tend to trust familiar names, organizations, or authority figures, making impersonation highly effective.
- Many users are unaware of common social engineering tactics, making them easier targets.
- A single successful attack can bypass advanced security systems without exploiting any technical vulnerability.

Example

"Your bank account has been suspended. Click here immediately."

Victims panic and click without verifying.

Types of Social Engineering

Social Engineering Attack Techniques



Types of Social Engineering

Phishing

- **Explanation:** Fraudulent emails or messages designed to trick users into revealing sensitive information or clicking malicious links.
Example: You receive an email claiming to be from your bank asking you to verify your account by clicking a fake login page.

Spear Phishing

- **Explanation:** A targeted phishing attack that uses personalized information to deceive a specific individual.
Example: An employee receives an email from a fake HR manager mentioning their name and requesting payroll login credentials.

Whaling

- **Explanation:** A phishing attack specifically aimed at senior executives or high-value individuals.
Example: A company's CFO receives an email appearing to be from the CEO requesting an urgent transfer of ₹25 lakh to a vendor.

Types of Social Engineering

Pretexting

- **Explanation:** An attacker creates a fake identity or believable story to obtain confidential information.
Example: Someone pretending to be an IT support engineer calls an employee and asks for their password to "fix a technical issue."

Scareware

- **Explanation:** Fake security warnings that frighten users into installing malicious software or paying for fake services.
Example: A pop-up appears saying, "**Your computer has 32 viruses! Click here to clean your PC now.**"

Baiting

- **Explanation:** Lures victims with an attractive offer to compromise their security.
Example: An attacker leaves a USB drive labeled "**2026 Employee Salary List**" in the office, hoping an employee plugs it into their computer.

Some Physical Social Engineering

Shoulder Surfing: The act of secretly observing someone to obtain confidential information such as passwords or PINs.

Dumpster Diving: Searching discarded documents or electronic waste to recover sensitive or confidential information.

Tailgating: Gaining unauthorized physical access by closely following an authorized person into a restricted area without authentication.

Piggybacking: Gaining unauthorized access with the assistance of an authorized person who allows entry into a secure area.

Preventing Social Engineering

- **Employee Awareness:** Educate employees to recognize and respond to social engineering attacks.
- **Cybersecurity Training:** Conduct regular training sessions on security threats and safe online practices.
- **Multi-Factor Authentication (MFA):** Require multiple forms of verification to secure user accounts.
- **Identity Verification:** Confirm a person's identity before sharing sensitive information or granting access.

Preventing Social Engineering

- **Clean Desk Policy:** Keep confidential documents and devices secured when not in use.
- **Visitor Management:** Monitor and control visitor access to prevent unauthorized entry.
- **Password Managers:** Use secure tools to generate and store strong, unique passwords.
- **Security Drills:** Regularly simulate cyberattacks to test employee awareness and incident response

Port Scanning

Port scanning is the process of identifying **open ports and services** running on a target system to assess its security and discover potential vulnerabilities.

Purpose

- Discover active network services running on the target.
- Identify potential security vulnerabilities.
- Detect the target operating system and service versions.
- Find possible entry points for further security testing.
- Verify firewall rules and network configurations.
- Assess the overall security posture of the target.

Port Scanning

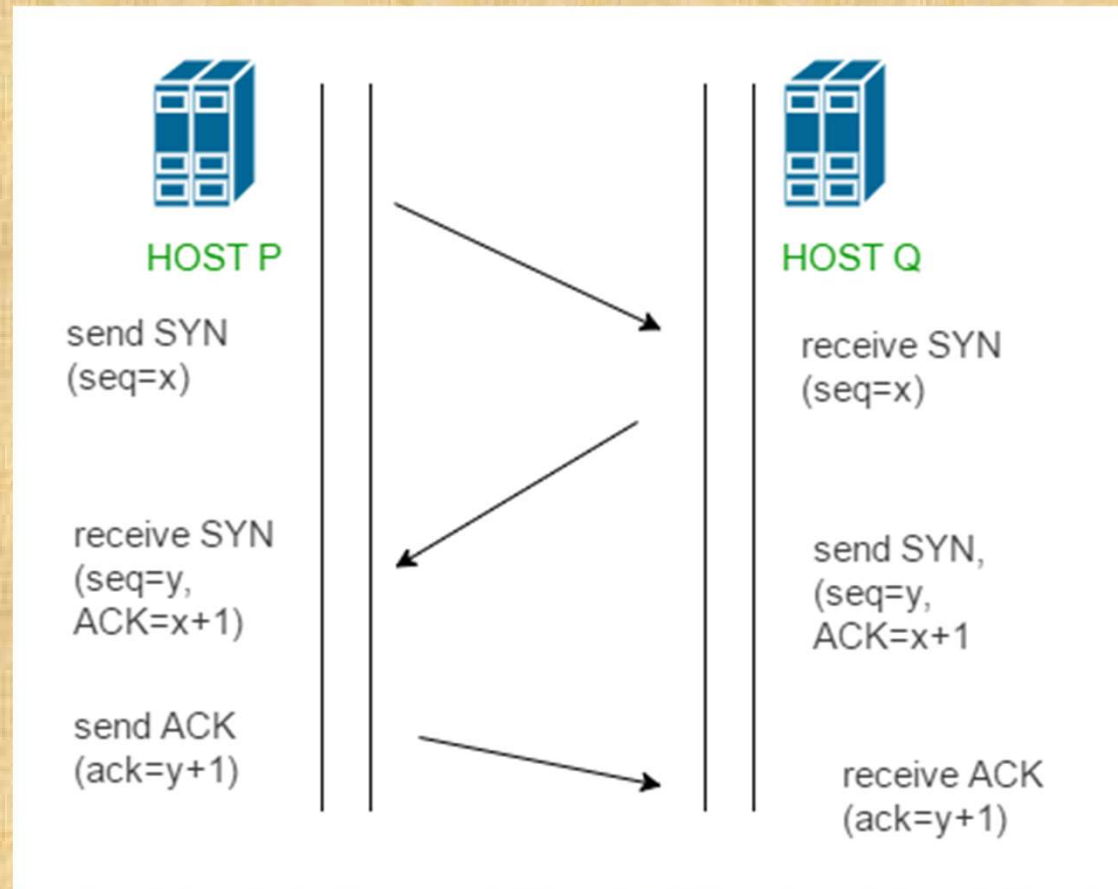
Common Port States

- **Open:** A service is actively listening for connections.
- **Closed:** The port is accessible but no service is running.
- **Filtered:** A firewall or security device is blocking access to the port.

Example

Port	Service
22	SSH (Secure Shell)
80	HTTP (Web Server)
443	HTTPS (Secure Web Server)
3306	MySQL Database

TCP Three-Way Handshake



Attackers use different scanning techniques by manipulating this handshake

TCP Three-Way Handshake

The TCP Three-Way Handshake is the process used to establish a **reliable connection** between a client and a server before data transmission begins.

Steps

Step 1: SYN (Synchronize)

- The client sends a **SYN** packet to the server.
- Indicates a request to establish a TCP connection.

Step 2: SYN-ACK (Synchronize-Acknowledge)

- The server responds with a **SYN-ACK** packet.
- Acknowledges the client's request and agrees to establish the connection.

Step 3: ACK (Acknowledge)

- The client sends an **ACK** packet to the server.
- Confirms receipt of the server's response and completes the connection.

TCP Three-Way Handshake

Purpose

- Establishes a reliable communication session.
- Synchronizes sequence numbers between client and server.
- Ensures both devices are ready for data transfer.
- Prevents incomplete or invalid connections.

Example

- When you open <https://www.google.com>, your computer first completes the TCP Three-Way Handshake with Google's web server before any webpage data is exchanged.

Exploiting the TCP Three-Way Handshake

Attackers abuse the TCP connection establishment process to disrupt services or gather information.

1. SYN Flood Attack

- Attacker sends a large number of **SYN** packets with spoofed IP addresses.
- The server allocates resources and waits for the final **ACK**, which never arrives.
- Half-open connections consume server resources.
- Can lead to **Denial-of-Service (DoS)** or **Distributed DoS (DDoS)**.

2. TCP Session Hijacking

- Attacker predicts or steals TCP sequence numbers.
- Injects malicious packets into an active TCP session.
- May gain unauthorized access or modify transmitted data.

Exploiting the TCP Three-Way Handshake

3. TCP Reset (RST) Attack

- Attacker sends forged **RST** packets.
- Forces the client or server to terminate an active TCP connection.
- Disrupts ongoing communication.

4. SYN Scan (Half-Open Scan)

- Used by penetration testers and attackers to identify open ports.
- Sends a **SYN** packet and observes the response without completing the handshake.
- Harder to detect than a full TCP connection.

Prevention

- Enable **SYN cookies** to protect against SYN flood attacks.
- Use **firewalls** and **Intrusion Detection/Prevention Systems (IDS/IPS)**.
- Rate-limit incoming SYN requests.
- Encrypt communications using **TLS/HTTPS**.
- Use random TCP sequence numbers and keep systems updated.

Enumeration

Enumeration is the process of **actively extracting detailed information** from target systems after scanning by establishing direct communication with network services.

Information Collected

- User accounts and usernames
- User groups and privileges
- Shared folders and network resources
- Operating system and version
- Password and account lockout policies
- Domain names and Active Directory information

Enumeration

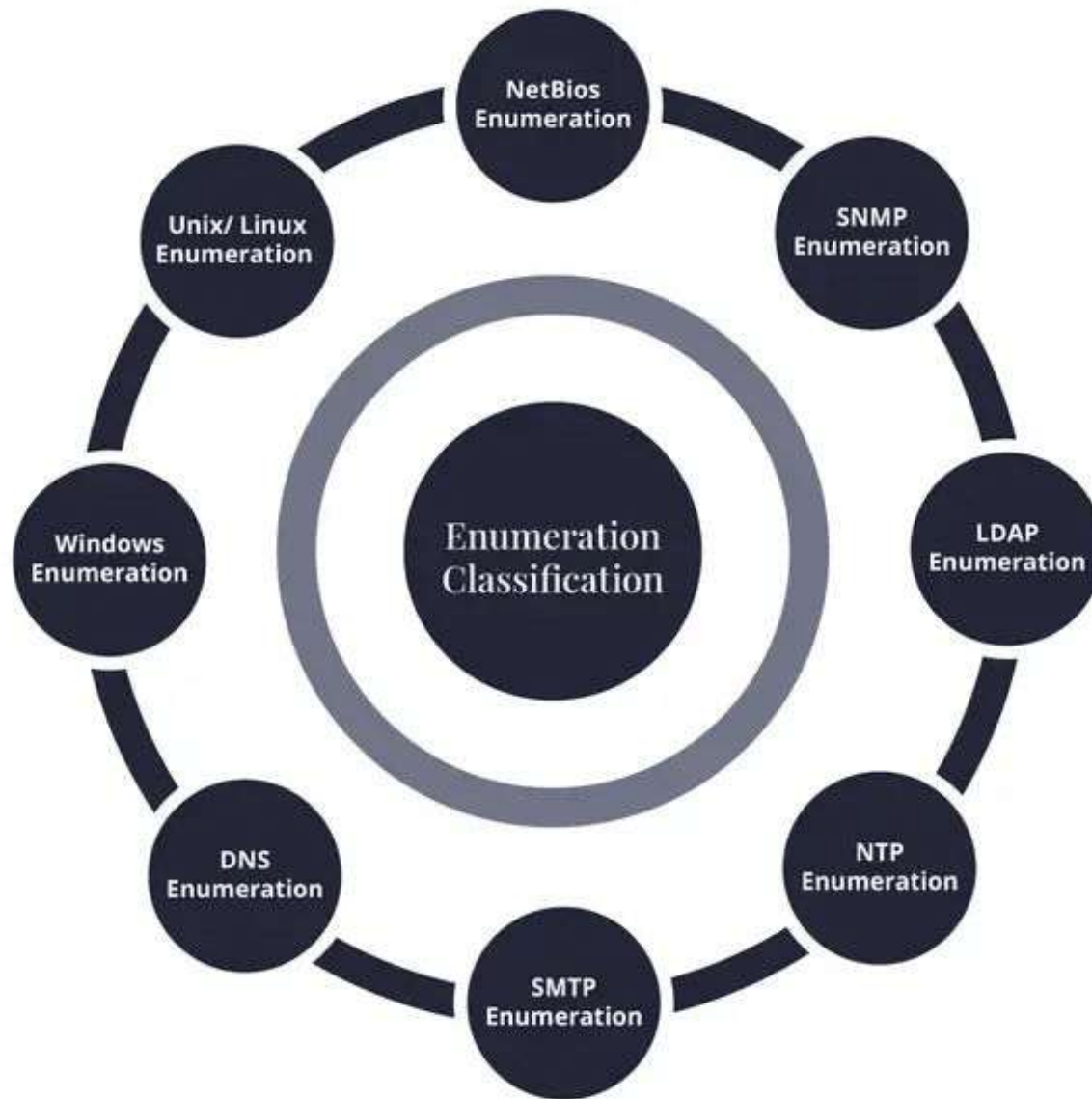
Purpose

- Identify valuable targets within the network.
- Gather detailed information for vulnerability assessment.
- Discover misconfigurations and weak security settings.
- Determine user privileges and access permissions.
- Identify potential attack paths for penetration testing.

Common Enumeration Protocols

- **SMB:** Shared folders and user information
- **NetBIOS:** Computer names and network resources
- **SNMP:** Network device configuration and status
- **LDAP:** Active Directory users, groups, and domains
- **DNS:** Hostnames and domain records

Enumeration Techniques



Enumeration Techniques

NetBIOS Enumeration: Retrieves computer names, shared resources, users, and workgroup/domain information from Windows systems.

SNMP Enumeration: Collects system, network, and device configuration information from SNMP-enabled devices.

LDAP Enumeration: Extracts user accounts, groups, organizational units, and Active Directory information.

NTP Enumeration: Gathers information about NTP servers, synchronization status, and network time configuration.

Enumeration Techniques

SMTP Enumeration: Identifies valid email accounts and mail server configuration through SMTP commands.

DNS Enumeration: Retrieves DNS records such as hostnames, IP addresses, mail servers, and subdomains.

Windows Enumeration: Collects detailed information about Windows users, groups, shares, services, and security policies.

Unix/Linux Enumeration: Gathers information about Linux users, groups, running services, permissions, and system configuration.

Enumeration Tools

Tool	Purpose
enum4linux	Enumerates SMB shares, users, groups, and domain information from Windows/Linux systems.
smbclient	Connects to SMB shares to access and list shared files and folders.
rpcclient	Retrieves Windows user accounts, groups, password policies, and domain information using RPC.
nbtscan	Scans for NetBIOS information, including hostnames, workgroups, and logged-in users.
SNMPwalk	Collects detailed information from SNMP-enabled devices, such as system details and network configuration.
Nmap NSE	Uses Nmap Scripting Engine scripts to automate service enumeration and vulnerability detection.

Real Life Example: TESLA

This workflow represents how an **authorized ethical hacker** performs reconnaissance during a penetration test.

Step 1: WHOIS Lookup

- Find domain registration details for **tesla.com**.
- Identify the registrar and name servers.

Step 2: DNS Enumeration

- Discover subdomains such as:
 - mail.tesla.com
 - vpn.tesla.com
 - careers.tesla.com

Real Life Example: TESLA

Step 3: Google Dorking

- Search for publicly available PDFs, job postings, and login portals.
- Identify technologies used by the company.

Step 4: Ping Sweep

- Identify live hosts within the target's IP range.

Step 5: Port Scanning (Nmap)

- Detect open ports such as:
 - **22** – SSH
 - **80** – HTTP
 - **443** – HTTPS

Real Life Example: TESLA

Step 6: Service Detection

- Identify running services and software versions.
- Detect the operating system and web server.

Step 7: Enumeration

- Enumerate SMB shares, DNS records, or publicly accessible information.
- Gather usernames, shared resources, or network details (only where authorized).

Step 8: Security Report

- Document discovered assets.
- Highlight exposed services and potential vulnerabilities.
- Recommend security improvements.

Summary

Phase	Goal	Output
Footprinting	Gather publicly available information	Domains, IPs, emails, technologies
Social Engineering	Exploit human behavior	Credentials, confidential information
Port Scanning	Discover open ports and services	Open ports, service versions
Enumeration	Retrieve detailed system information	Users, groups, shares, OS, domain details

Dr.Indu Singh CSE DTU